Artificial Intelligence and Large Language Model Acceptable Use and Governance Policy

Policy ID: POL-AI-005 | Version 1.0 | Classification: Internal

Policy Owner	Chief AI Officer / CISO / Data Protection Officer	**Effective Date**	12 September 2026
Review Cycle	At least annually and upon material legal, threat, technology, or business change	**Approval Authority**	Executive Risk / Information Security Governance Committee
Applies To	Enterprise workforce, controlled entities, and in-scope suppliers	**Control Status**	Mandatory unless formally excepted

Mandatory language: "MUST" and "MUST NOT" indicate mandatory requirements. "SHOULD" indicates an expected control that may be varied only when a risk-based alternative is documented. "Strictly Prohibited" identifies conduct that is not permitted absent an explicit, legally valid emergency or exception pathway.

1. Objective

This policy establishes mandatory governance for enterprise use of artificial intelligence (AI), machine learning (ML), generative AI, foundation models, large language models (LLMs), AI agents, embeddings, vector databases, retrieval-augmented generation, model fine-tuning, and AI-assisted software development. The objective is to enable useful AI adoption while protecting confidential information, personal data, intellectual property, security boundaries, legal obligations, and human decision quality.

2. Scope

This policy applies to all employees, contractors, suppliers, products, internal tools, pilots, prototypes, customer-facing features, development assistants, autonomous or semi-autonomous agents, external AI SaaS, self-hosted models, model APIs, training/fine-tuning datasets, prompt logs, outputs, and AI-generated code or content used for enterprise purposes.

3. Governance, Accountability, and Roles

AI Governance Committee. Classifies use cases, sets prohibited/high-risk categories, approves material external deployments, and monitors risk.

Model / Product Owners. Maintain model cards or equivalent documentation, evaluations, intended-use boundaries, data sources, deployment controls, and rollback plans.

Security. Reviews model access, agent permissions, prompt-injection controls, secret exposure, supply chain, and abuse monitoring.

Privacy / Legal. Reviews personal-data use, training rights, automated decision impacts, licensing, disclosure, and regulatory obligations.

Users. Must verify AI outputs before relying on them and must not disclose restricted information to unapproved services.

4. Policy Rules and Mandatory Guidelines

- Only enterprise-approved AI services and models MAY be used for enterprise data. Consumer AI accounts, personal subscriptions, and unapproved browser extensions MUST NOT receive Confidential, Restricted, customer, employee, source-code, credential, or non-public business information.
- AI output MUST be treated as untrusted until verified. It MUST NOT be represented as fact, legal advice, security assurance, compliance evidence, financial advice, or customer commitment without qualified human review appropriate to impact.

- High-impact decisions affecting employment, credit, eligibility, safety, access to essential services, disciplinary outcomes, or legal rights MUST NOT be made solely by generative AI unless explicitly permitted by law and approved through the enterprise high-risk AI process with meaningful human oversight.
- Sensitive personal data, production secrets, private keys, credentials, authentication tokens, unreleased source code, incident details, and privileged legal communications MUST NOT be entered into external AI services unless a written enterprise agreement and technical controls explicitly authorize that data category.
- Enterprise data submitted to third-party AI services MUST NOT be used for provider model training unless explicitly approved by the data owner, Legal/Privacy, and AI Governance. Contractual no-training/no-retention settings MUST be enabled where available for sensitive use cases.
- AI-generated code is not exempt from engineering standards. Developers remain responsible for correctness, licensing, security, tests, vulnerability remediation, and maintainability of generated code.
- Agents capable of taking actions MUST use least privilege, bounded tools, allowlisted destinations, transaction limits, and explicit approval gates for consequential operations. Giving an AI agent unrestricted shell, production administrator, payment, identity-management, or data-deletion privileges is Strictly Prohibited.
- Prompt injection, data poisoning, malicious retrieved content, and tool-output manipulation MUST be considered in the threat model for RAG and agentic systems. Retrieved content MUST NOT be treated as trusted instructions simply because it appears in an enterprise knowledge source.
- Customer-facing AI MUST disclose AI involvement where required by law, contract, product policy, or risk assessment. Systems MUST provide an escalation or human-assistance path where material user harm could result from incorrect output.
- Training, fine-tuning, evaluation, or embedding of datasets MUST have documented provenance and permitted use. Scraped, leaked, pirated, or unlawfully obtained datasets are prohibited.
- Biometric identification, covert employee surveillance, emotion inference, social scoring, deceptive impersonation, or other prohibited/high-risk AI uses MUST NOT be deployed without explicit Legal/Privacy and executive approval and, where prohibited by law or enterprise policy, MUST NOT be deployed at all.
- AI evaluation results, safety limitations, known failure modes, and material hallucination or bias risks MUST NOT be concealed from approvers, auditors, or affected internal stakeholders.

5. Technical and Coding Constraints

- LLM applications MUST separate system/developer instructions from untrusted user/retrieved content and SHOULD implement structured tool schemas, allowlists, output validation, and explicit authorization checks outside the model.
- A model MUST NOT be relied upon to enforce access control. Authorization MUST be performed by deterministic application logic before data is retrieved or an action is executed.
- RAG systems MUST enforce source-level permissions at retrieval time. Embeddings or vector indexes containing restricted information MUST be protected to the same classification as the source data.
- Secrets MUST NOT be placed in prompts, system messages, model weights, client-side bundles, evaluation datasets, or logs. Model API credentials MUST be stored in approved secret managers and scoped/rotated.
- AI endpoints MUST use authenticated TLS, rate limits, abuse controls, logging, and cost/quota safeguards. Public unauthenticated model endpoints that can access enterprise data or tools are prohibited.
- AI-generated code MUST pass SAST, SCA, secret scanning, tests, and code review before merge. Generated cryptographic, authentication, authorization, parsing, memory-unsafe, or infrastructure code requires heightened review.
- Self-hosted models, weights, adapters, tokenizers, and inference runtimes MUST be obtained from approved sources, scanned, version-pinned, license-reviewed, and isolated from production credentials during evaluation.
- Model and agent logs MUST minimize personal and confidential data. Full prompts/responses MAY be retained only under approved retention and access controls; high-risk secrets must be redacted before logging.

- Production AI services MUST support rollback or disablement. Model/version changes that can materially affect behavior MUST undergo evaluation before production promotion.
- Evaluation suites MUST include task quality plus relevant safety dimensions such as hallucination, prompt injection resistance, sensitive-data leakage, harmful tool use, authorization bypass attempts, and domain-specific bias/robustness.

6. Operational Control Requirements

- AI use cases MUST be registered before production. Risk tiering MUST consider autonomy, data sensitivity, external impact, scale, reversibility, legal/regulatory relevance, and whether outputs trigger real-world actions.
- Material incidents including sensitive-data leakage, unsafe autonomous action, model compromise, systemic harmful output, or exploitation of an AI component MUST be handled under the incident-response process.
- High-risk AI systems MUST be periodically re-evaluated because models, prompts, tools, data sources, and external attack techniques change over time.

7. Monitoring, Assurance, and Records

Compliance with this policy MUST be demonstrable. Evidence is part of the control, not an optional administrative artifact. Records MUST be retained according to the enterprise records-retention schedule, legal holds, applicable regulation, and contractual requirements.

Minimum expected records:

- AI use-case register
- Model cards/system documentation
- Evaluation reports
- Threat models
- Training/fine-tuning dataset provenance
- Provider assessments and contracts
- Human-oversight procedures
- Incident and rollback records

Security, Internal Audit, Privacy, Legal, Compliance, and authorized risk functions MAY request evidence and perform sampling or technical validation. System owners MUST provide accurate evidence and MUST NOT suppress, alter, or fabricate control records.

8. Enforcement and Violation Consequences

Security, AI Governance, or Legal may suspend an AI service, model, integration, dataset, or agent immediately when material risk is identified. Violations may lead to loss of AI-tool access, blocked deployment, disciplinary action, supplier remediation, customer notification, regulatory escalation, or termination for deliberate misuse.

Where a violation creates active risk, protective action may occur before disciplinary or contractual review is complete. Enforcement decisions will consider intent, recurrence, severity, impact, legal duties, and whether the individual promptly reported the issue and cooperated with remediation.

9. Exceptions and Risk Acceptance

Exceptions MUST state the use case, model/provider, data classes, autonomy level, actions/tools, affected users, evaluation results, threat model, legal/privacy analysis, compensating controls, monitoring, accountable owner, and expiration. No exception permits an AI system to bypass statutory rights, access-control requirements, or credential handling rules.

An exception MUST NOT be interpreted as permanent policy change. The control owner may require additional monitoring, narrower scope, remediation milestones, or earlier review. Expired exceptions automatically cease to

authorize the deviation.

10. Standards and Regulatory Alignment

This policy is designed to support the enterprise ISMS and cybersecurity risk program. Mappings are implementation aids; they do not replace a formal applicability analysis, legal advice, or the authoritative standards and regulations.

Framework	Policy alignment
ISO/IEC 27001:2022	Supports risk governance, supplier security, access control, secure development, information classification, logging, privacy, and incident-management objectives.
NIST CSF 2.0	GV.OC/GV.RM/GV.SC AI risk governance and suppliers; ID.RA risk assessment; PR.AA/PR.DS/PR.PS controls; DE.CM monitoring; RS/RC incident and recovery.
GDPR	Articles 5, 6, 9, 13-15, 22, 25, 28, 32 and 35 are relevant where AI processes personal data or supports automated decision-making.

Authoritative reference set

- ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection - Information security management systems - Requirements. This policy supports the ISMS risk-management model and applicable Annex A controls without reproducing proprietary standard text.
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024). Control outcomes are organized across GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, and RECOVER as applicable.
- Regulation (EU) 2016/679 (General Data Protection Regulation, GDPR), including the principles of Article 5 and, where applicable, Articles 6, 25, 28, 30, 32, 33, 34, 35, and Chapter V on international transfers.

11. Review, Maintenance, and Approval

The policy owner MUST review this document at least annually and whenever a material incident, audit finding, law/regulation, technology change, threat development, merger/acquisition, or operating-model change may affect its adequacy. Proposed changes MUST be version-controlled and approved through the enterprise policy governance process. Local procedures may impose stricter requirements but MUST NOT weaken this policy without an approved exception.

End of controlled document.